

Forensic reconciliation audit — private case evidence workstream

Scope: reconcile the requirements raised in issues #24/#25 and pull requests #26/#27/#28/#29/#32 against the code actually present on the integration line, resolve the PR #32 packaging review concerns, and record exactly what is verified, what is disabled, and what is missing. No merge, deploy, production migration, flag change or production secret change was performed. Private-workspace flags remain absent from `.env` (fail-closed).

Method and limits of this audit

Inclusion was judged by tracing commit ancestry **and** reading the current implementation, not by merged status. Verification for each requirement is grounded in a specific test run or a direct source read. The following could NOT be verified in this environment and are called out as pending, never as done:

- **Issues #24/#25 text** — the available GitHub token lacks the Issues:Read permission (the issues API returns HTTP 403 “Resource not accessible by personal access token”). The #24/#25 acceptance criteria below are reconstructed from the PR descriptions and `docs/private-case-timeline.md`; the original issue wording could not be read. Rotate/expand the token to close this gap.
- **Hosted database** — only in-memory PGlite with the real migration SQL was exercised. No hosted database concurrency, backup or restore was tested.
- **Deployed browser** — no two-account isolation test, no upload/review/export/revocation walk-through, and no PDF rendering were exercised in a deployed browser.
- **Collaboration end-to-end** — there is no multi-user invitation flow to exercise (see the collaboration section); isolation was tested only at the service/HTTP fixture level.

A synthetic parser test is not end-to-end acceptance and is not treated as such anywhere below.

A. Branch / PR reconciliation (is any work lost?)

Remote heads at audit time: `main` = `1c8437a`; `integrate/evidence-search` = `922be13`; `packaging/self-contained-worker` (PR #32 head) = `fdb7818`. All of #26/#27/#28/#29/#32 are OPEN; none merged.

Ancestry (verified with `git merge-base --is-ancestor`):

- PR #29 head `dc6ba9b` IS an ancestor of both `922be13` and `fdb7818`.
- PR #26 (`81c8068`), #27 (`79f41c04`), #28 (`d08f048`) original heads are NOT ancestors of either — but their code was carried forward through PR #29’s single integration commit.

Content-level check (each PR’s changed files diffed against `fdb7818`):

PR	Substantive code at #32 head	Dropped
#26 owner-bound PDF jobs	All 5 code/test files identical (generate-pdf/route.ts , generate-pdf/status/route.ts , lib/pdf-job-access.mjs , lib/pdf-job-handlers.ts , tests/pdf-job-access.test.mjs)	docs/pdf-export-containment.md only
#27 workspace dashboard	All 7 present: 4 identical (app/workspace/page.tsx , components/workspace/workspace-client.mjs , tests/tsconfig.workspace-ui.json , tests/workspace-client.test.mjs), 3 enhanced by #29 (docs/private-workspace-ui.md , components/site-header.tsx , components/workspace/workspace-dashboard.tsx)	none
#28 workspace foundation	code/schema/migration/test identical; lib/workspaces/http.ts refactored by #29 (functionality preserved: auth() , prisma adapter, Serializable transaction, flag gate)	docs/private-workspace-foundation.md only
#29 evidence+timeline	present (it is the integration commit)	none

Conclusion: no substantive code from #26/#27/#28 was lost. Two design/handoff docs (pdf-export-containment.md , private-workspace-foundation.md) are not on the integration line; their content is largely superseded by docs/private-case-timeline.md . If those docs are wanted verbatim, recover them with `git show 81c8068:docs/pdf-export-containment.md` and `git show d08f048:docs/private-workspace-foundation.md` .

B. Requirement reconciliation

Status vocabulary: **tested** (implemented with an automated test that ran this audit); **unverified** (implemented, read in source, but no automated/hosted/browser proof of the end-to-end behaviour); **disabled** (implemented but gated off pending release requirements); **missing**; **deferred** (explicitly out of scope in docs/private-case-timeline.md).

Requirement	Source	Implementation	Evidence	Status
Email/password authentication	#24	next-auth; auth() in lib/ workspaces/ http.ts	source read	unverified for confidential use
MFA / trusted identity provider	#24, release gate	not implemen- ted	private-case- timeline.md re- lease blocker	missing (release blocker)
Create work- space / case / named sites	#24, #28	lib/workspaces/ service.ts createWorkspace / createCase (+sites, creat- or→OWNER)	private-work- spaces.test.ts in the 28-test run	tested (fixture) + disabled (flag off)
Server-side workspace AND case member- ship enforce- ment	#24, #28	service.ts workspaceAccess / caseAccess with FOR SHARE , revokedAt IS NULL ; http.ts Serializable	included in 28- test run	tested (fixture); hosted two-ac- count test pending
Uploads, email attachments, duplicate hand- ling, amend- ments, quotas	#24, #29	lib/workspaces/ case-files.ts import (hash de- dup → 409 on metadata con- flict, super- sedesId , quotas 100 docs/50 MiB/1500 pas- sages/150 per doc, SHA-256 in- tegrity recheck, nested attach- ments); parse- file.mjs	case- files.test.ts in 28-test run	tested (fixture, synthetic files)
Extraction with real source loca- tions	#24, #29	parse-file.mjs (PDF page pas- sages ≤100pp, DOCX offsets, EML	28-test run; standalone pars- er exercised in packaging build	tested (fixture)

Requirement	Source	Implementation	Evidence	Status
		body+attachments depth≤1, TXT/CSV, PNG/JPEG→NEEDS_OCR)		
OCR / scanned-image transcription	#24	not implemented (NEEDS_OCR marker only)	private-case-timeline.md “Not included”	deferred
Review, amendments, optimistic concurrency, audit trail	#24, #29	case-files.ts review (revision concurrency → 409, quote must be substring, accept/draft/reject, note), PrivateWorkspaceAudit , PrivateCase-EventRevision	28-test run	tested (fixture)
Literal search across authorised cases	#25, #29	case-files.ts search (position(lower(\$4) in lower(p.text)) , membership-filtered in SQL, cross-case earlier flag, LIMIT 50)	28-test run	tested (fixture)
Semantic/vector search, entity linking across cases	#25	not implemented	private-case-timeline.md “Not included”	deferred
Timeline + reveal slider	#25, #29	components/workspace/case-evidence.tsx Timeline tab + slider; eventQuery or-	workspace-client.test.mjs (UI-source structure) in 28-test run	unverified (no browser); UI source tested

Requirement	Source	Implementation	Evidence	Status
		der eventDate ASC NULLS LAST		
Maps / satellite / historical comparison	#25	not implemented (slider is a timeline, not a map)	private-case-timeline.md “Not included”	deferred
Reviewed PDF export + provenance manifest, versioned, re-authorised download	#24/#25, #29	case-files.ts export (ACCEPTED-only, manifest with parser/renderer versions + revisions + hashes + excluded drafts + PDF hash; limits 400 entries/150 pages/5 MiB/20 exports; re-auth downloadExport), render-case.ts (pdf-lib)	case-files.ts export path in 28-test run; pdf-job-access.test.mjs (10)	tested (fixture); PDF-in-deployed-browser pending
Legacy external PDF job containment	#24, #26	owner-bound AES-256-GCM job receipts, 15-min, fail-closed	pdf-job-access.test.mjs in 28-test run	tested; off by default
At-rest protection of extracted text/metadata/review history	release gate	file/PDF bytes AES-256-GCM; extracted passages/metadata/review history NOT app-encrypted	private-case-timeline.md	missing (release blocker)
Host protection (scanner, constrained parser runtime, quotas)	release gate	clamscan required at runtime; child process cap 20 s / 128 MiB; not a full sandbox	private-case-timeline.md	disabled/partial (release blocker)

Requirement	Source	Implementation	Evidence	Status
Hosted persistence, backup/restore, retention	release gate	additive migration exists; only PGlite tested	private-case-timeline.md	missing (release blocker)

C. Collaboration and reporting reconciliation

These were raised directly by the requester. Each is reported as its ACTUAL status, distinguishing an existing requirement from a proposed addition. The data model supports far more than the delivered API/UI.

1. **Invite named colleagues; grant/revoke case access.** Schema (`PrivateWorkspaceMember` , `PrivateCaseMember` with `role` , `canExport` , `revokedAt`) and server-side enforcement (`service.ts` access checks honour `revokedAt`) exist. **There is no invitation, add-member, grant-role or revoke API or UI** — `createWorkspace` / `createCase` only make the creator an OWNER. Status: **missing (data model ready)**. This is the single clearest gap blocking a multi-user pilot.
2. **Contributor / reviewer / viewer roles + separate export permission.** `service.ts` `permits(role, action, canExport)` enforces OWNER/CONTRIBUTOR/REVIEWER/VIEWER, with export gated on a separate `canExport` flag an owner toggles for their own exports. Enforcement is present and unit-tested; **assigning a role to another user is missing** because member management is missing. Status: **enforcement tested; role assignment missing**.
3. **Comments, review decisions, follow-up questions, audit trail.** Review decisions (ACCEPTED/DRAFT/REJECTED), appended revisions, a free-text `note` field labelled “Review rationale / unresolved question”, and a `PrivateWorkspaceAudit` table all exist and are tested at fixture level. A **standalone comment thread and a discrete follow-up-question entity are not present** — today a follow-up question is a `note` on a review revision, not a separate object. Status: **decisions + audit tested; threaded comments / question objects are a proposed addition**.
4. **Report from SELECTED reviewed evidence, with citations, unresolved gaps, versioned export.** Export produces a PDF + manifest from **all ACCEPTED entries** (including labelled superseded and unknown-date records), not a user-selected subset; UI filters do not change the export. Citations (name, locator, documentId, SHA-256, source URL, publication, quote, note) are present in the manifest, and exports are versioned and retained (limit 20). A **user-selected subset and an explicit “unresolved gaps” report section are not implemented as specified**. Status: **partial** — citations + versioning tested; selection + gaps section proposed.
5. **Sharing/export must not expose other cases or the whole workspace.** Export is scoped to a single `workspaceId` + `caseId` ; `downloadExport` requires `requestedBy` to equal the acting member; search only spans the actor’s member cases. Isolation is enforced in code and tested at the service/HTTP fixture level. Status: **enforced (fixture-tested); hosted two-account test pending**.

D. PR #32 packaging fixes (bounded, this audit)

1. **Pin esbuild and commit a portable lockfile without touching the platform store.** `esbuild` (which produces the deterministic `public/parser/worker.mjs`) was only a transitive dependency; the managed lockfile constrained it merely to `~0.25.0 / >=0.12 <1` , while the byte-identical

bundle needs exactly `0.28.2`. esbuild is now an explicit dev dependency pinned to `0.28.2` in `nextjs_space/package.json`. The repo's `yarn.lock` is a **git-tracked symlink** into the platform-managed store, so the repository carries no resolvable lockfile of its own; rather than hand-edit that symlink or the shared store, a portable copy of the store's fully-resolved lockfile is committed at `nextjs_space/ci/yarn.lock`. It carries no machine-specific paths (`0 /home`, `0 /opt`, `0 file:` refs; its only workspace ref is `app@workspace:.`, which matches the repo package name) and pins the exact versions the committed worker was built from (esbuild `0.28.2`, pdfjs-dist `6.3.289`, mammoth `1.12.2`, mailparser `3.9.23`, jszip `3.10.1` and the rest of the graph). The shared managed store lockfile was left byte-for-byte unchanged.

2. Add a CI integrity workflow (not automatically required). Ad-

ded `.github/workflows/parser-worker-integrity.yml`. On pull requests into `integrate/evidence-search` and `main` (and pushes to them) it replaces the platform lockfile symlink with the committed `ci/yarn.lock`, runs `yarn install --immutable` (so no new versions are silently resolved), and runs `yarn check:worker`. Adding this workflow file does **not** by itself make the check required: a maintainer must enable the check named **Parser worker integrity / check-worker** as a required status check under Settings → Branches. The workflow deliberately has no `paths:` filter, so it runs on every qualifying event and is therefore compatible with being marked required (a `paths` - filtered required check can hang permanently pending when the path is untouched). It is kept out of `yarn run build`, so bundle drift can never abort a production deploy. Because the fresh install has no access to the managed store, a green run also proves the bundle reproduces off-platform.

3. Fix silently skipped licence attribution. `scripts/build-parser-worker.mjs` resolved each inlined package via `require.resolve('<pkg>/package.json')` and did `catch { continue }` — silently dropping any package whose `exports` map blocks that subpath. The generator now resolves the actual package directory for every entry in esbuild's input graph (including nested versions), inspects licence filenames **case-insensitively** (`/^(licen[cs]e|copying|notice)/i`), collects all matches including `NOTICE` files, and **throws** if any inlined package cannot be attributed. Regenerated artifacts now document **53 inlined packages: 51 attributed from bundled licence/ NOTICE files, and 2 reconstructed from a canonical SPDX template** — `dingbat-to-unicode@1.0.1` (BSD-2-Clause) and `isarray@1.0.0` (MIT) — because those two ship no standalone li-

cence file in their published package. Both are clearly labelled as non-verbatim reconstructions in `worker.LICENSES.txt`, and neither the file header nor the manifest claims complete verbatim attribution while they remain reconstructed. The seven previously-dropped packages (`deepmerge-ts`, `dom-serializer`, `domelementtype`, `domhandler`, `domutils`, `entities`, `htmlparser2`) are now attributed from their bundled files. This attribution work alone did not change `worker.mjs`; the bytes changed separately (see fix 4) through path normalisation only.

4. Make the worker bytes reproducible off-platform. esbuild follows the workspace

`node_modules` symlink into the platform store and baked that absolute store path (`/opt/hosted-app/node/root/app_next_16/node_modules/...`) into the bundle's module-key strings and `//` path comments, so a fresh install with a real `node_modules` produced a non-byte-identical worker. The shared build config now sets `preserveSymlinks: true`, so both the platform (symlinked) build and a genuinely fresh install emit stable `node_modules/<pkg>/...` paths. This changed `public/parser/worker.mjs` from sha256 `ac385816...` to `c39f2bc8...` — a path-normalisation change only, with no code or dependency change (verified: the sole differences were path-key strings and path comments) — and it removes the leaked host path from the committed bundle. Verified with a genuinely fresh `yarn install --immutable` from `ci/yarn.lock` in an isolated directory (real `node_modules`, local cache): the lockfile was left unmutated and `yarn check:worker` reproduced the committed worker byte-for-byte.

5. **PR description.** A complete description (diff, validation, limitations, rollback) is prepared at `docs/pr-32-description.md` for the requester to apply to PR #32.

E. Verification log (this audit)

Run from `nextjs_space` unless noted. Working tree on branch `pr32-corrections` (based on PR #32 head `fdb7818` via review checkout `fc64e30`), with the section D fixes applied and committed for a non-force update of PR #32.

Check	Command	Result
Private + PDF suites	<code>node --import ./node_modules/tsx/dist/loader.mjs --test tests/case-files.test.ts tests/private-workspaces.test.ts tests/workspace-client.test.mjs tests/pdf-job-access.test.mjs</code>	28 pass / 0 fail
Evidence regression	<code>node --import ./node_modules/tsx/dist/loader.mjs --test tests/evidence-*.test.ts tests/place-history.test.ts tests/investigation-coverage.test.ts</code>	25 pass / 0 fail
Types	<code>node node_modules/typescript/bin/tsc --noEmit --incremental false</code>	exit 0
Schema	<code>node node_modules/prisma/build/index.js validate</code>	valid
Worker integrity	<code>yarn check:worker</code>	passed (esbuild 0.28.2; deps match; re-bundle byte-identical)
Faithful standalone build	platform packaging (copy managed app dir, rsync working tree, <code>NEXT_OUTPUT_MODE=standalone</code> yarn run build)	exit 0; worker.mjs present in <code>.build/standalone/app/public/parser/</code> (sha <code>c39f2b-c8...</code>); pdfjs-dist / mammoth / mailparser absent from standalone <code>node_modules</code> ; no worker-resolution errors

F. Handoff

1. Work preserved. All substantive code from PRs #26/#27/#28 is present on the integration line via PR #29; #29 and #32 are present. Only two design docs (`pdf-export-containment.md` , `private-workspace-foundation.md`) are off the integration line and are recoverable from their PR heads.

2. Genuinely missing. Member invitation / role-assignment / revoke API and UI (schema ready). MFA / trusted identity provider. At-rest encryption of extracted passages, metadata and review history. Hosted persistence with backup/restore/retention. Threaded comments and a discrete follow-up-question object. User-selected export subset and an explicit “unresolved gaps” report section. OCR, maps/satellite comparison, semantic search and cross-case entity linking are explicitly deferred, not accidental gaps.

3. Exists but disabled or unverified. The whole private workspace/case/evidence journey is implemented and passes fixture-level tests but is disabled in production (all three flags absent, fail-closed) and unverified in a hosted database and a deployed browser. Isolation is enforced and fixture-tested but has no hosted two-account proof. The reviewed-PDF export is fixture-tested but not verified rendering in a deployed browser.

4. Is PR #32 ready to merge into `integrate/evidence-search` ? The packaging change itself is sound and now well-evidenced: byte-identical self-contained worker (sha `c39f2bc8...` , reproducible from a fresh `--immutable` install via `ci/yarn.lock`), integrity check green, faithful standalone build green with the unmodified platform config, corrected licence attribution (51 of 53 inlined packages from bundled files, 2 reconstructed and labelled), an explicit esbuild pin and a CI integrity workflow (present but not yet a required check). With the section D fixes applied it is reasonable to merge **after** (a) the requester reviews the fixes, (b) the CI workflow runs green on the PR, and (c) the empty PR body is replaced with `docs/pr-32-description.md` . It does not enable any confidential-use feature, so merging it does not itself create pilot risk. The section D fixes are committed on `pr32-corrections` and pushed as a non-force (fast-forward) update to PR #32’s head branch `packaging/self-contained-worker` ; no merge, deploy, production migration or private-feature activation was performed.

5. Smallest next task toward a usable pilot. Implement **case member management**: an owner-only API to invite an existing account to a case, assign CONTRIBUTOR/REVIEWER/VIEWER, toggle export permission, and revoke — plus a minimal owner UI. This is the smallest change that turns a single-owner tool into the multi-user, role-separated, revocable-access workflow the requester described, and the schema already supports it. Acceptance criteria: an owner can add account B to a case with a chosen role; B sees only that case and only the actions its role permits; export is blocked for B until the owner grants `canExport` ; after the owner revokes B, B can no longer read, search or download prior exports; every add/role-change/revoke writes a `PrivateWorkspaceAudit` row; a non-owner cannot invite or change roles; all of this is covered by a two-account fixture test and then confirmed once in a hosted two-account browser session. This deliberately excludes MFA and at-rest encryption, which remain independent release blockers.